

SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

Marco Estratégico — Versión 2.0 (Post-Auditoría)

Institución:	Liceo Técnico Profesional Gonzalo Guglielmi de Yumbel
Normativa Base:	ISO/IEC 27001:2022
Cumplimiento Legal:	Ley N.º 21.663 (Ciberseguridad) · Ley N.º 21.719 (Datos Personales)
Web Institucional:	www.liceotpggm.cl
Versión:	2.0 — Revisada y Corregida Post-Auditoría
Fecha de Emisión:	28 de julio de 2026
Clasificación:	CONFIDENCIAL — Solo para uso de la Dirección

Este documento ha sido elaborado por el Encargado de Soporte Informático del Liceo, en cumplimiento de la Ley N.º 21.663 y la Ley N.º 21.719, y bajo los estándares de la norma ISO/IEC 27001:2022. Su reproducción o distribución fuera de la Dirección institucional requiere autorización expresa.

1. Alcance del SGSI

El alcance del Sistema de Gestión de Seguridad de la Información (SGSI) del Liceo Técnico Profesional Gonzalo Guglielmi comprende la protección integral de los activos de información críticos que sustentan los procesos académicos, administrativos y formativos de la institución, considerando de manera prioritaria el entorno escolar con presencia de estudiantes menores de edad.

Activos Críticos Definidos:

- **Registros Académicos e Historial Escolar:** Notas, controles de asistencia, anotaciones de convivencia y evaluaciones, almacenados en la plataforma de gestión educativa **Napsis** y en repositorios institucionales internos.
- **Datos Personales y Sensibles:** Información de identidad, antecedentes de salud (fichas médicas escolares, alergias), situación socioeconómica e información de contacto de estudiantes, apoderados, docentes y personal administrativo.
- **Infraestructura Tecnológica:** Laboratorios de computación técnica, red Wi-Fi institucional, servidores locales, equipos administrativos y sistemas de videovigilancia.
- **Proveedores Externos Críticos:** Napsis (plataforma SaaS de gestión académica), proveedor de servicios de internet (ISP), proveedor de solución antivirus y cualquier otro tercero que procese datos institucionales.

2. Política de Seguridad de la Información

Declaración de la Política:

El Liceo Técnico Profesional Gonzalo Guglielmi de Yumbel se compromete a proteger la confidencialidad, integridad y disponibilidad de la información de toda su comunidad educativa. Este compromiso se sustenta en la mejora continua del SGSI, el estricto cumplimiento de la legislación nacional vigente y el fomento de una cultura preventiva de seguridad digital en todos sus actores.

Objetivos Estratégicos:

1. **Protección del Entorno Educativo:** Garantizar un entorno digital seguro que proteja incondicionalmente la privacidad e integridad de los menores de edad y el personal del establecimiento.
2. **Desarrollo de Competencias Digitales:** Alinear la ciberseguridad institucional con la formación de competencias digitales de los estudiantes técnicos, promoviendo el uso ético, responsable y seguro de la tecnología.
3. **Continuidad Operativa:** Asegurar la disponibilidad de las plataformas educativas, sistemas administrativos y laboratorios de computación, garantizando la continuidad del proceso de enseñanza-aprendizaje incluso ante incidentes.
4. **Cumplimiento Normativo:** Satisfacer a cabalidad los requisitos de la Ley N.º 21.663, la Ley N.º 21.719 y las cláusulas de la norma ISO/IEC 27001:2022.

3. Análisis de Riesgos

La gestión de riesgos sigue una metodología simplificada basada en **MAGERIT v3**, adaptada a la realidad técnica y presupuestaria del liceo. Cada riesgo se evalúa con la fórmula: **Nivel de Riesgo = Probabilidad × Impacto** (escala 1–3 en ambos ejes).

3.1 Metodología de Valoración

Probabilidad	Valor	Impacto	Valor
Improbable (< 1 vez / año)	1	Leve (sin afectación de datos sensibles ni interrupción)	1
Posible (1–3 veces / año)	2	Moderado (afecta parcialmente servicios o datos de un grupo)	2
Probable (> 3 veces / año)	3	Grave (filtración masiva, interrupción total de clases, sanción legal)	3

3.2 Registro de Riesgos Priorizados

#	Amenaza	Probabilidad	Impacto	Nivel	Tratamiento
R-01	Fuga de datos sensibles por phishing a docentes/administrativos	3	3	**9 — CRÍTICO**	Mitigar: MFA + capacitación
R-02	Acceso no autorizado a Napsis (modificación de notas/asistencia)	2	3	**6 — ALTO**	Mitigar: Gestión de accesos + MFA
R-03	Ransomware / cifrado de equipos administrativos o laboratorios	1	3	**3 — MEDIO**	Mitigar: Backups 3-2-1 + BCP
R-04	Malware por USB en laboratorios de computación	3	2	**6 — ALTO**	Mitigar: Bloqueo USB + antivirus
R-05	Caída de servicio de Napsis (falla del proveedor)	2	2	**4 — MEDIO**	Transferir: DPA con Napsis + contingencia manual

#	Amenaza	Probabilidad	Impacto	Nivel	Tratamiento
R-06	Pérdida o robo de dispositivo con datos personales	2	2	**4 — MEDIO**	Mitigar: Cifrado de disco en portátiles
R-07	Acceso de menores a contenido inapropiado en red escolar	3	1	**3 — MEDIO**	Mitigar: Firewall + filtrado de contenido

3.3 Declaración de Aplicabilidad (SoA) — Extracto de Controles Relevantes

La selección de controles del Anexo A de ISO 27001:2022 se justifica a continuación. Los controles excluidos obedecen a la escala del liceo y serán reconsiderados en revisiones anuales.

Control ISO 27001:2022	Aplicable	Justificación
A.5.1 Políticas de seguridad	■ Sí	Base del SGSI
A.5.3 Segregación de funciones	■ Sí	Exigido por auditoría
A.5.19 Seguridad en relaciones con proveedores	■ Sí	Napsis, ISP y antivirus
A.5.30 Preparación TIC para continuidad	■ Sí	BCP ante ransomware
A.6.3 Concientización y capacitación	■ Sí	Personal y estudiantes
A.7.1 Perímetros de seguridad física	■ Sí	Sala de servidores / laboratorios
A.8.5 Autenticación segura (MFA)	■ Sí	Napsis y correo institucional
A.8.13 Respaldo de la información	■ Sí	Regla 3-2-1
A.8.7 Protección contra malware	■ Sí	Antivirus + filtrado USB
A.8.24 Uso de criptografía	■ Sí	Cifrado de portátiles
A.5.9 Inventario de activos	■ Sí	Inventario de datos personales
A.5.28 Recolección de evidencia	■ Sí	Bitácora de incidentes ARCO

4. Controles Priorizados (Basado en Anexo A — ISO/IEC 27001:2022)

4.1 Controles Organizativos

- **Políticas de Uso Aceptable:** Normativas claras, documentadas y firmadas sobre el uso de recursos tecnológicos (computadores de laboratorio, red Wi-Fi, correos institucionales) por parte de estudiantes, docentes y administrativos. Revisión anual obligatoria.
- **Clasificación de la Información:** Etiquetado formal según nivel de sensibilidad: *Público / Uso Interno / Confidencial (Datos de Menores)*.
- **Gestión de Incidentes:** Protocolo estandarizado para que cualquier miembro de la comunidad educativa reporte eventos sospechosos al Encargado de Soporte Informático, con formulario de reporte disponible en secretaría y en www.liceotpggm.cl.
- **Gestión de Relaciones con Proveedores (A.5.19):** El liceo exigirá y suscribirá un **Acuerdo de Procesamiento de Datos (DPA)** con Napsis y con cualquier proveedor externo que trate datos personales de la comunidad educativa. El DPA debe especificar: finalidad del tratamiento, medidas de seguridad, prohibición de cesión a terceros, procedimiento de notificación de brechas y ubicación del almacenamiento de datos. Este acuerdo es condición sine qua non para la contratación o renovación del servicio.

4.2 Controles de Personas (Capacitación y Concientización)

- **Programa de Concientización en Ciberseguridad:** Capacitación anual y obligatoria para directivos, docentes y administrativos, enfocada en: detección de phishing, gestión segura de contraseñas, cuidado de la información del alumnado y reporte de incidentes.
- **Educación Digital para Estudiantes:** Incorporación de módulos de seguridad de la información, privacidad y huella digital en las mallas curriculares de los laboratorios de computación técnica.
- **Inducción al SGSI para Personal Nuevo:** Todo funcionario que ingrese al liceo deberá recibir una inducción de 30 minutos en políticas de seguridad antes de acceder a sistemas institucionales.

4.3 Controles Físicos

- **Seguridad de Servidores y Redes:** Control de acceso físico estricto (cerradura con llave exclusiva del Encargado de Soporte Informático y del Director(a)) a la sala de servidores/rack de comunicaciones. Registro de accesos en bitácora física.
- **Gestión de Laboratorios:** Restricciones de uso fuera de horario supervisado; inventario actualizado de equipos; bloqueo de puertos USB en equipos de laboratorio mediante política de grupo (GPO) para prevenir infección por malware.
- **Protección de Puestos de Trabajo:** Directriz de "pantalla bloqueada y escritorio limpio" para el personal administrativo y docente que gestione registros escolares. Tiempo máximo de inactividad antes del bloqueo automático: 5 minutos.

4.4 Controles Tecnológicos

- **Control de Accesos y Autenticación (A.8.5):** Implementación de Autenticación Multifactor (MFA) para el acceso de docentes y administrativos a Napsis y correos institucionales desde redes externas, **sujeto a soporte técnico del proveedor**. En caso de que Napsis no disponga de MFA nativo en el plan contratado, se aplicarán los siguientes **controles compensatorios**: restricción de acceso a Napsis exclusivamente desde la red institucional del liceo (filtrado por IP), configuración de sesiones con tiempo de expiración máximo de 30 minutos, y auditoría mensual de registros de acceso.

- **Cifrado de Datos (A.8.24):** Cifrado de disco completo (BitLocker o equivalente) en todos los computadores portátiles asignados a docentes y directivos. Cifrado de bases de datos locales con información sensible.
- **Gestión de Respaldos (A.8.13):** Sistema automatizado de respaldos bajo la **regla 3-2-1**: 3 copias de los datos, en 2 soportes distintos (disco local + nube), con 1 copia en ubicación física fuera del liceo. Pruebas documentadas de restauración con frecuencia semestral.
- **Protección contra Malware y Filtrado de Contenido (A.8.7):** Antivirus gestionado centralizadamente en todos los equipos. Firewall perimetral con filtrado de contenido web que bloquee categorías inapropiadas para menores. Bloqueo de ejecución automática desde dispositivos USB.
- **Plan de Continuidad TIC (A.5.30):** Ante un incidente mayor (ransomware, caída prolongada de Napsis), se activará el **Plan de Continuidad** que establece: uso de registros físicos de respaldo (libro de clases impreso), comunicación de contingencia por correo electrónico y WhatsApp institucional, y plazo máximo de 48 horas para la restauración de sistemas críticos desde los respaldos. El plan se revisará y probará anualmente mediante un ejercicio de simulacro.

5. Gobernanza y Responsabilidades (Cumplimiento Ley N.º 21.663)

5.1 Estructura de Roles (Segregación de Funciones — A.5.3)

Para garantizar la continuidad operativa del SGSI y el cumplimiento del principio de segregación de funciones, se definen los siguientes roles con responsabilidades claramente diferenciadas:

- **Director(a) del Liceo (Responsable del SGSI ante la Ley):**
 - Aprueba y firma la Política de Seguridad.
 - Es la autoridad legal responsable ante la ANCI y la APDP en caso de incidente.
 - Preside el Comité de Seguridad de la Información.
 - Autoriza el inicio del protocolo de reporte a la ANCI cuando el Encargado le notifica un incidente.
- **Encargado de Soporte Informático (Responsable Técnico Operativo del SGSI):**
 - Implementa, opera y monitorea los controles técnicos del SGSI.
 - Gestiona altas/bajas de accesos de usuarios, administra respaldos y actualizaciones.
 - Lidera la contención técnica inicial ante cualquier incidente.
 - Redacta los reportes técnicos para la ANCI (Fases 1, 2 y 3).
 - Mantiene el inventario de datos y la bitácora ARCO actualizados.
- **Suplencia:** En ausencia (licencia, vacaciones, desvinculación), la Dirección designará un funcionario de confianza como responsable técnico provisional, quien deberá ser notificado al CSIRT-GOV como punto de contacto actualizado.
- **Comité de Seguridad de la Información Escolar:**
 - Integrado por: Director(a), Encargado de Soporte Informático, Inspectoría General y un representante docente.
 - Se reúne **trimestralmente** y de forma extraordinaria ante cualquier incidente categoría NARANJA o ROJO.
 - Evalúa riesgos, aprueba presupuestos de seguridad, revisa el cumplimiento de políticas y valida el informe anual del SGSI.

5.2 Protocolo de Notificación de Incidentes a la ANCI (Proceso Trifásico Obligatorio)

El Liceo Técnico Profesional Gonzalo Guglielmi, en su calidad de institución que administra servicios esenciales para la comunidad estudiantil, seguirá el siguiente proceso ante incidentes de ciberseguridad significativos, de conformidad con los Arts. 26, 36 y 40 de la Ley N.º 21.663:

- **Fase 1 — Notificación Preliminar (Plazo: dentro de las 3 horas desde la detección):**

El Encargado de Soporte Informático o, en su ausencia, el Director(a) del Liceo, reportará al **CSIRT-GOV** (www.csirt.gob.cl), indicando: fecha y hora de detección, tipo y nivel de incidente (según tabla de categorización), sistemas afectados e impacto estimado. Esta notificación es de carácter preliminar y no requiere un análisis forense completo.

- **Fase 2 — Reporte Técnico Detallado (Plazo: dentro de las 72 horas desde la detección):**

Informe técnico completo con causa raíz identificada, activos comprometidos, datos personales afectados (especificando si corresponden a menores de edad), medidas de contención adoptadas y evaluación de daños. Si en este punto se confirma afectación de datos personales, se activa simultáneamente el protocolo de notificación a la **Agencia de Protección de Datos Personales (APDP)**, conforme al Art. 66 de la Ley N.º 21.719.

- **Fase 3 — Informe Final de Cierre (Plazo: dentro de los 30 días corridos desde la detección):**

Documento formal con análisis de causa raíz, lecciones aprendidas, controles correctivos implementados y medidas para evitar la recurrencia. Aprobado por el Director(a) antes de su envío.

5.3 Tabla de Categorización de Incidentes del Liceo (Referencia ANCI)

Nivel	Color ANCI	Ejemplo en el Liceo	Acción
1	■ AZUL	Intento de phishing detectado y bloqueado sin éxito	Registrar; no requiere reporte externo
2	■ VERDE	Acceso no autorizado a correo institucional de un docente	Registrar; evaluar con Comité
3	■ AMARILLO	Malware activo en laboratorio sin propagación a red administrativa	Reportar a CSIRT-GOV (Fase 1 en 3h)
4	■ NARANJA	Filtración de datos de hasta 50 estudiantes o personal	Reportar a CSIRT-GOV + APDP (Fase 1 en 3h)
5	■ ROJO	Ransomware institucional o filtración masiva de datos de menores	Reportar a CSIRT-GOV + APDP + activar BCP (Fase 1 en 3h)

Responsabilidad legal: El Director(a) del liceo, en su calidad de Jefe de Servicio, responde personalmente ante la ANCI por el incumplimiento de los plazos establecidos. La omisión de reporte constituye infracción grave, sancionable con multa de hasta **10.000 UTM** al sostenedor institucional (SLEP o DAEM), conforme al Art. 41 de la Ley N.º 21.663.

6. Protección de Datos Personales (Cumplimiento Ley N.º 21.719)

6.1 Base de Licitud para el Tratamiento de Datos

El Liceo fundamenta el tratamiento de datos personales de sus estudiantes (incluidos los menores de edad) en las siguientes bases de licitud, en orden de aplicación preferente, conforme al Art. 13 de la Ley N.º 21.719:

- 1. **Obligación legal (base principal):** El tratamiento de datos necesario para la gestión académica —registro de notas, asistencia, convivencia escolar y certificación de estudios— constituye el cumplimiento de obligaciones legales establecidas en la **Ley N.º 20.370 (LGE)** y sus reglamentos. Esta base **no requiere consentimiento del apoderado y no puede ser revocada** unilateralmente.
- 2. **Interés legítimo (base secundaria):** Para tratamientos conexos no exigidos expresamente por ley, pero necesarios para el funcionamiento del liceo (ej. comunicaciones con apoderados, uso de plataformas de gestión interna como Napsis).
- 3. **Consentimiento informado (base complementaria — solo para tratamientos no obligatorios):** Se recabará el consentimiento **libre, específico, informado, unívoco y separado** del apoderado, mediante formulario físico o digital **autónomo** (nunca vinculado al formulario de matrícula), exclusivamente para tratamientos opcionales tales como: uso de imagen o voz del menor en redes sociales o difusión institucional, publicación de trabajos académicos con identificación del estudiante, o participación en programas externos de investigación educativa.

6.2 Inventario de Datos Personales

El liceo mantiene un **Registro de Actividades de Tratamiento (RAT)**, actualizado semestralmente por el Encargado de Soporte Informático y validado por el Director(a), que detalla:

Categoría de Dato	Base de Licitud	Almacenamiento	Responsable de Acceso	Plazo de Retención
RUT, nombre, domicilio del estudiante	Obligación legal (LGE)	Napsis + archivo físico	Director, Secretaria	Permanente (registro histórico)
Notas y calificaciones	Obligación legal (LGE)	Napsis + libro de clases	Director, Docentes, Jefe UTP	Permanente
Registro de asistencia	Obligación legal (LGE)	Napsis	Inspectoría	5 años
Anotaciones de convivencia	Obligación legal (LGE)	Napsis + archivo físico	Inspector General	5 años post-egreso
Fichas de salud / alergias	Obligación legal (Reglamento MINSAL)	Archivo físico (enfermería)	Encargado(a) de Salud	Vigencia del estudiante

Categoría de Dato	Base de Licitud	Almacenamiento	Responsable de Acceso	Plazo de Retención
Datos de apoderados y contactos	Interés legítimo	Napsis	Inspección, Secretaría	Vigencia del estudiante
Imágenes / registros fotográficos	Consentimiento	Servidor local / RRSS	Director + autorización	Hasta revocación

6.3 Gestión del Consentimiento Informado

- Al momento de la matrícula escolar, se informará a los apoderados sobre qué datos se tratarán, con qué finalidad y bajo qué base legal, mediante la **Ficha de Información de Tratamiento de Datos**, sin que esto implique una solicitud de consentimiento para datos de tratamiento obligatorio.
- Para tratamientos opcionales, se presentará un formulario de consentimiento **separado, claro y voluntario**, con opción de aceptación independiente por cada finalidad (*opt-in*). La negativa del apoderado a estos consentimientos opcionales **no podrá condicionar la matrícula ni afectar la prestación del servicio educativo**.

6.4 Ejercicio de Derechos ARCO — Procedimiento Formal

El liceo garantiza el ejercicio **gratuito y expedito** de los siguientes derechos, conforme a los Arts. 11 a 20 de la Ley N.º 21.719:

Canales de contacto:

- Correo electrónico: privacidad@liceotpggm.cl
- Formulario en línea: www.liceotpggm.cl
- Formulario físico: disponible en Secretaría del establecimiento

Legitimación activa (¿quién puede ejercer estos derechos?):

- El apoderado o tutor legal, en nombre de un estudiante **menor de 14 años**.
- El propio estudiante, si tiene **14 años o más**, respecto de derechos relativos a su vida privada.
- El personal del liceo, respecto de sus propios datos personales.

Verificación de identidad: Toda solicitud ARCO requerirá la presentación de cédula de identidad vigente del solicitante y, si actúa a nombre de un menor, del documento que acredite el vínculo de representación legal (libreta de familia, resolución judicial de tutoría, etc.).

Plazos de respuesta legales:

Derecho	Descripción	Plazo máximo	Extensión posible
Acceso	Saber qué datos posee el liceo y cómo los trata	30 días corridos	15 días adicionales con justificación escrita
Rectificación	Corregir datos inexactos, desactualizados o incompletos	30 días corridos	15 días adicionales con justificación escrita

Derecho	Descripción	Plazo máximo	Extensión posible
Cancelación / Supresión	Eliminar datos cuando ya no sean necesarios	30 días corridos	No aplica si hay retención legal obligatoria
Oposición	Negarse a tratamientos no esenciales (ej. difusión en RRSS)	30 días corridos	15 días adicionales con justificación escrita

Registro y trazabilidad: El Encargado de Soporte Informático llevará una **Bitácora de Solicitudes ARCO** que registre: fecha de recepción, identidad del solicitante, derecho ejercido, fecha de respuesta y resultado obtenido. Esta bitácora es **fiscalizable por la APDP** en cualquier momento.

Limitaciones legales: La cancelación de datos no procede cuando la conservación del registro sea exigida por ley (ej. libro de clases histórico, certificados de estudios, antecedentes de convivencia escolar por el período de retención establecido).

7. Acuerdos de Procesamiento de Datos con Terceros (DPA)

El liceo, en su calidad de **responsable del tratamiento**, exige a todos sus proveedores tecnológicos la suscripción de un **Acuerdo de Procesamiento de Datos (DPA)** como condición de contratación o renovación del servicio. Este acuerdo debe incluir:

- Finalidad específica y limitada del tratamiento de datos.
- Medidas técnicas y organizativas de seguridad implementadas por el proveedor.
- Prohibición expresa de cesión o sublicencia de datos a terceros sin autorización previa y escrita del liceo.
- Procedimiento y plazo de notificación al liceo ante una brecha de seguridad en el lado del proveedor (plazo máximo: 24 horas desde la detección).
- Ubicación geográfica y jurisdicción legal del almacenamiento de datos (preferentemente en Chile o en países con nivel de protección equivalente).
- Obligación de devolver o destruir los datos al término del contrato.

Proveedores que requieren DPA de forma inmediata: Napsis, proveedor de ISP (si gestiona logs de navegación), proveedor de antivirus en la nube.

Borrador para revisión.